ALPE FORMACIÓN · SANTANDER

Edición 2026 · PHP 8.x

CURSO DE PHP · CLASE 11

Formularios, archivos y ficheros

- Repaso rápido: $_GET y $_POST
- El patrón del formulario profesional
- Validar: comprobar que el dato es correcto
- Escapar: htmlspecialchars y los ataques XSS
- Guardar datos en un fichero JSON
- Post/Redirect/Get: adiós al «¿Desea reenviar el formulario?»
- Subir archivos
- Para saber más: ficheros CSV



Ramón Abramo

+25 años de experiencia docente · Santander, Cantabria

ALPE

FORMACIÓN PROFESIONAL

🧭 Contenido de la clase

Hasta ahora éramos nosotros quienes escribíamos los datos en el código. Pero una web de verdad es **interactiva**: los usuarios escriben su nombre, eligen opciones, suben fotos y pulsan botones. Hoy aprendemos a **recibir** todo eso, a **comprobarlo** y a **guardarlo** en ficheros.

Ya hicisteis un formulario en la clase 6. Hoy lo convertimos en uno «profesional»: que muestre los errores junto a cada campo, que no borre lo que el usuario ya había escrito y que no se deje colar código malicioso.

Os adelanto la frase de la clase, la que os voy a repetir hasta que la soñéis: **nunca os fiéis de lo que envía el usuario**.

1 📘 Repaso rápido: $_GET y $_POST



2 👌 El patrón del formulario profesional



3 🤔 Validar: comprobar que el dato es correcto



4 🐞 Escapar: htmlspecialchars y los ataques XSS



5 👍 Guardar datos en un fichero JSON



6 😮 Post/Redirect/Get: adiós al «¿Desea reenviar el formulario?»



7 🚀 Subir archivos



8 🔍 Para saber más: ficheros CSV



9 🚀 Ejercicios



10 👋 Lo que tenéis que llevaros de hoy





CLASE 11 · PUNTO 1

📘 Repaso rápido: $_GET y $_POST

PHP guarda lo que llega del navegador en unos arrays especiales, las **superglobales**, disponibles en cualquier parte del código [1]:

	`$_GET`	`$_POST`
Dónde viajan los datos	En la URL, tras el `?`: `buscar.php?q=zapatos`	Ocultos en el cuerpo de la petición
Se pueden guardar en favoritos o compartir	✅ Sí	❌ No
Úsalo para...	Búsquedas, filtros, número de página	Registros, logins, altas y cualquier cosa que **cambie** datos



⚠️ **Las contraseñas, siempre por POST.** Por GET acabarían en la barra de direcciones, en el historial del navegador y a la vista de cualquiera que mire la pantalla.



CLASE 11 · PUNTO 2

👌 El patrón del formulario profesional

Vamos a escribir un formulario de contacto que se procesa **en el mismo archivo**. Fijaos en que sigue el orden de programa que vimos en la clase 9, porque lo usaréis siempre:

Parte	En un formulario
Funciones	`e()` para escapar y `validarContacto()`, que devuelve un array con los errores
Inicialización	`$errores = [];` y `$enviado = false;`
Entradas	¿Me han enviado el formulario? (`$_SERVER["REQUEST_METHOD"]`) y los datos, limpios con `trim()`
Procesamiento	Si es un envío: validar y, si no hay errores, procesar (guardar, enviar...)
Salidas	El HTML: los errores y el formulario con lo que el usuario ya había escrito

Y en código:

01-formulario-contacto.php — php-paso-a-paso/clase11 — Visual Studio Code

01-formulario-contacto.php

```php
<?php
declare(strict_types=1);

function e(string $texto): string
{
    return htmlspecialchars($texto, ENT_QUOTES, "UTF-8");
}

function validarContacto(string $nombre, string $email): array
{
    $errores = [];
    if ($nombre === "") {
        $errores[] = "El nombre es obligatorio.";
    }
    if (filter_var($email, FILTER_VALIDATE_EMAIL) === false) {
        $errores[] = "El email no tiene un formato válido.";
    }
    return $errores;
}

$errores = [];
$enviado = false;

$esEnvio = $_SERVER["REQUEST_METHOD"] === "POST";
$nombre = trim($_POST["nombre"] ?? "");
$email = trim($_POST["email"] ?? "");

if ($esEnvio) {
    $errores = validarContacto($nombre, $email);
    $enviado = count($errores) === 0;
}
?>
<!-- y aquí, el HTML -->
```

En el HTML volvemos a poner en cada campo lo que el usuario escribió, para que no tenga que rellenarlo todo otra vez por un solo error:

01-formulario-contacto.php — php-paso-a-paso/clase11 — Visual Studio Code

01-formulario-contacto.php

```php
<input type="text" name="nombre" value="<?= e($nombre) ?>">
```

¿Y qué hace exactamente esa `e()`? Lo explico en el punto 4.

📄 Ejemplo completo: `01-formulario-contacto.php`



💡 **¿Por qué `REQUEST_METHOD` y no `isset($_POST["enviar"])`?** Porque si el usuario envía el formulario pulsando **Intro** en lugar del botón, en algunos casos el botón no viaja y vuestro código no se enteraría del envío. Preguntar por el método funciona siempre.

✅ Tres pruebas para comprobarlo

Haced esto	Debéis obtener
Enviad el formulario vacío	Tres errores en rojo
Escribid un nombre y un email mal escrito	Un error del email... **y el nombre sigue escrito**
Rellenadlo bien	El mensaje de agradecimiento



CLASE 11 · PUNTO 3

🤔 Validar: comprobar que el dato es correcto

Validar es comprobar que lo que llega tiene sentido **antes** de usarlo. Y ojo: el atributo `required` del HTML ayuda al usuario, pero **no os protege**. Cualquiera puede saltárselo desde las herramientas del navegador. La validación de verdad se hace **siempre en PHP**.

Qué comprobar	Cómo
Campo obligatorio	`trim($dato) === ""`
Longitud mínima o máxima	`mb_strlen($dato) < 10`
Email	`filter_var($email, FILTER_VALIDATE_EMAIL)` [2]
Número entero en un rango	`filter_var($edad, FILTER_VALIDATE_INT, ["options" => ["min_range" => 16, "max_range" => 99]])`
Valor de una lista (un `<select>`)	`in_array($ciudad, $ciudades, true)`
Dos campos iguales (contraseñas)	`$clave === $clave2`



🎯 **Truco:** si guardáis los errores con el nombre del campo como clave (`$errores["email"] = "..."`), luego podéis mostrar cada error **justo debajo de su campo**. Lo tenéis en la solución del ejercicio 01.



CLASE 11 · PUNTO 4

🐞 Escapar: htmlspecialchars y los ataques XSS

Imaginad un libro de visitas. Alguien escribe esto como «mensaje»:

02-xss.php — php-paso-a-paso/clase11 — Visual Studio Code

🌐 02-xss.php

```
<script>alert('¡Te he hackeado!')</script>
```

Si lo mostráis tal cual con `echo`, el navegador de **cada persona que visite la página** ejecutará ese código. Una alerta es inofensiva, pero en su lugar podría haber un script que robe sesiones. Este ataque se llama **XSS** (*Cross-Site Scripting*) y es de los más comunes en la web [3].

La defensa es sencilla: **escapar** todo lo que venga del usuario antes de mostrarlo. `htmlspecialchars()` convierte los caracteres peligrosos en texto inofensivo [4]:

Carácter	Se convierte en
`<`	`<`
`>`	`>`
`"`	`"`
`'`	`'`

El navegador **muestra** `<script>` en pantalla como texto, pero ya **no lo ejecuta**.

Como lo vais a escribir cientos de veces, mi recomendación es crear una función corta:

02-xss.php — php-paso-a-paso/clase11 — Visual Studio Code

🐘 02-xss.php

```php
<?php
function e(string $texto): string
{
    return htmlspecialchars($texto, ENT_QUOTES, "UTF-8");
}

echo "<p>" . e($comentario) . "</p>";
```

📄 Ejemplo: `02-xss.php`



🛡️ **Las dos reglas de oro: validad al entrar** (¿el dato tiene sentido?) y **escapad al salir** (¿se puede mostrar sin peligro?). Son dos cosas distintas, y hacen falta las dos.



CLASE 11 · PUNTO 5

👍 Guardar datos en un fichero JSON

Hasta que veamos bases de datos, podemos guardar información en **ficheros**. El formato más cómodo es **JSON**: un texto que representa arrays y que entienden PHP, JavaScript y casi cualquier lenguaje [5].

datos.json — php-paso-a-paso/clase11 — Visual Studio Code

datos.json

```
[
    { "nombre": "Ana", "texto": "Hola clase", "fecha": "06/11/2026 17:45" }
]
```

Solo necesitáis cuatro funciones:

Función	Qué hace
`json_encode($array)`	Array → texto JSON
`json_decode($texto, true)`	Texto JSON → array (el `true` es para que devuelva un array asociativo)
`file_put_contents($ruta, $texto)`	Escribe un texto en un fichero (lo crea si no existe)
`file_get_contents($ruta)`	Lee un fichero entero y lo devuelve como texto

03-libro-visitas.php — php-paso-a-paso/clase11 — Visual Studio Code

03-libro-visitas.php

```php
<?php
$archivo = __DIR__ . "/datos/visitas.json";

// Leer
$visitas = [];
if (file_exists($archivo)) {
    $visitas = json_decode(file_get_contents($archivo), true) ?? [];
}

// Añadir y guardar
$visitas[] = ["nombre" => $nombre, "texto" => $texto];
file_put_contents($archivo, json_encode($visitas, JSON_PRETTY_PRINT |
JSON_UNESCAPED_UNICODE), LOCK_EX);
```

Tres detalles de ese código:

- `__DIR__` es la carpeta donde está el archivo PHP. Con `__DIR__ . "/datos/..."` la ruta funciona aunque mováis el proyecto de sitio.
- `JSON_PRETTY_PRINT` y `JSON_UNESCAPED_UNICODE` hacen que el fichero sea legible y que las tildes se vean bien.
- `LOCK_EX` evita que dos personas escriban a la vez y se estropee el fichero.

📄 Ejemplo: `03-libro-visitas.php`. Abrid `datos/visitas.json` después de firmar: es texto normal.



CLASE 11 · PUNTO 6

😮 Post/Redirect/Get: adiós al «¿Desea reenviar el formulario?»

Firmad en el libro de visitas y pulsad **F5**. Si no hacemos nada, el navegador pregunta «¿Desea reenviar el formulario?»... y si decís que sí, la firma se guarda **dos veces**. En una tienda, sería un pedido duplicado. 😬

La solución es un patrón con nombre propio: **Post/Redirect/Get**. Después de procesar el POST con éxito, **redirigimos** a la misma página con una petición GET:

ejemplo.php — php-paso-a-paso/clase11 — Visual Studio Code

ejemplo.php

```php
<?php
// ...guardar los datos...
header("Location: 03-libro-visitas.php?ok=1");
exit;
```

Ahora F5 recarga el GET, que es inofensivo. Y el `?ok=1` nos sirve para mostrar el mensaje de «¡Gracias por firmar!».



⚠️ **Nunca olvidéis el `exit;` después de `header("Location: ...")`.** La cabecera le dice al navegador que se vaya, pero PHP **sigue ejecutando** lo que hay debajo si no lo paráis [6].

⚠️ Y `header()` tiene que ir **antes de cualquier salida**: ni un `echo`, ni HTML, ni un espacio en blanco antes. Si no, veréis el famoso error *«headers already sent»*. Por eso procesamos el formulario arriba del todo y el HTML va después.



CLASE 11 · PUNTO 7

🚀 Subir archivos

Para subir fotos o documentos, el formulario necesita dos cosas: `method="post"` y, **obligatoriamente**, `enctype="multipart/form-data"`. Sin ese atributo, el archivo no viaja.

04-subir-foto.php — php-paso-a-paso/clase11 — Visual Studio Code

🌐 04-subir-foto.php

```
1 <form method="post" enctype="multipart/form-data">
2     <input type="file" name="foto">
3     <button type="submit">Subir</button>
4 </form>
```

Los archivos no llegan a `$_POST`, sino a `$_FILES` [7]:

Clave en `$_FILES["foto"]`	Qué contiene
`["name"]`	El nombre original en el ordenador del usuario. **No lo uséis para guardar**
`["tmp_name"]`	Dónde lo ha dejado PHP temporalmente. Es el archivo de verdad
`["size"]`	Tamaño en bytes
`["error"]`	`UPLOAD_ERR_OK` (vale 0) si todo ha ido bien

Las comprobaciones que no podéis saltaros

04-subir-foto.php — php-paso-a-paso/clase11 — Visual Studio Code

04-subir-foto.php

```php
<?php
$foto = $_FILES["foto"] ?? null;
$tiposPermitidos = ["image/jpeg" => "jpg", "image/png" => "png", "image/webp" => "webp"];

if ($foto === null || $foto["error"] !== UPLOAD_ERR_OK) {
    $mensaje = "No ha llegado ningún archivo.";
} elseif ($foto["size"] > 2 * 1024 * 1024) {
    $mensaje = "Máximo 2 MB.";
} else {
    $info = getimagesize($foto["tmp_name"]);     // ¿es de verdad una imagen?
    $tipo = $info["mime"] ?? "";

    if (!isset($tiposPermitidos[$tipo])) {
        $mensaje = "Solo JPG, PNG o WEBP.";
    } else {
        $nombreFinal = bin2hex(random_bytes(8)) . "." . $tiposPermitidos[$tipo];
        move_uploaded_file($foto["tmp_name"], __DIR__ . "/uploads/" . $nombreFinal);
    }
}
```

¿Por qué tanto lío?

- **Comprobamos el contenido, no el nombre.** Cualquiera puede llamar `foto.jpg` a un programa malicioso. `getimagesize()` mira dentro del archivo.
- **Inventamos un nombre nuevo y aleatorio.** Así nadie puede sobrescribir otro archivo ni colar un nombre peligroso.
- `move_uploaded_file()` mueve el archivo temporal a su sitio definitivo. Si no lo movéis, PHP lo borra al terminar.

📄 Ejemplo: `04-subir-foto.php`



💡 Si una foto grande da error aunque esté por debajo de vuestro límite, revisad `upload_max_filesize` y `post_max_size` en el `php.ini` (en Laragon: **Menú → PHP → php.ini**). Recordad que con `phpinfo()` podéis ver qué valores tenéis.



CLASE 11 · PUNTO 8

🔍 Para saber más: ficheros CSV

Un **CSV** es una tabla en texto: una fila por línea y los valores separados por `;` o `,`. Excel los abre directamente, así que son perfectos para exportar listados.

05-csv.php — php-paso-a-paso/clase11 — Visual Studio Code

05-csv.php

```php
<?php
$f = fopen(__DIR__ . "/datos/alumnos.csv", "w");    // abrir para escribir
fputcsv($f, ["Marta", 22, "Santander"], ";");
fclose($f);                                          // cerrar siempre
```

Para leerlos se usa `fgetcsv()` dentro de un `while`, línea a línea.

📄 Ejemplo: `05-csv.php`



CLASE 11 · PUNTO 9

🚀 Ejercicios

- ☐ **01 · Registro.** Nombre, email, edad (entre 16 y 99), ciudad (un `<select>`) y contraseña repetida dos veces (mínimo 8 caracteres). Cada error debe aparecer **debajo de su campo** y los datos deben conservarse (menos las contraseñas). → `ej01-registro.php`
- ☐ **02 · Encuesta.** «¿Qué lenguaje te gusta más?» con botones de radio. Guardad los votos en un JSON, aplicad Post/Redirect/Get y mostrad los resultados con su porcentaje. → `ej02-encuesta.php`
- ☐ **03 · Galería.** Un formulario para subir fotos a la carpeta `fotos/` y, debajo, todas las fotos subidas. Pista: `glob()` os da la lista de archivos de una carpeta. → `ej03-galeria.php`



🏆 **Reto:** en el libro de visitas, probad a firmar con `<b>Hola</b>` como mensaje. ¿Sale en negrita? ¿Por qué no? Ahora quitad la `e()` en esa línea y repetid la prueba. Volved a ponerla en cuanto lo veáis. 😉



CLASE 11 · PUNTO 10

👋 Lo que tenéis que llevaros de hoy

Idea	En una frase
GET o POST	GET para consultar, POST para enviar o cambiar datos. Contraseñas, siempre por POST
¿Me han enviado el formulario?	`$_SERVER["REQUEST_METHOD"] === "POST"`
Validar	En PHP, siempre. El `required` del HTML no protege
Escapar	`htmlspecialchars()` (nuestra `e()`) en todo lo que venga del usuario
Conservar datos	`value="<?= e($nombre) ?>"`
JSON	`json_encode` / `json_decode` + `file_put_contents` / `file_get_contents`
PRG	Tras un POST correcto: `header("Location: ...")` y `exit;`
Subidas	`enctype="multipart/form-data"`, `$_FILES`, comprobar tipo y tamaño, nombre aleatorio

📚 Fuentes y documentación oficial

1. Manual de PHP: superglobales
2. Manual de PHP: filtros de validación
3. OWASP: Cross Site Scripting (XSS)
4. Manual de PHP: htmlspecialchars
5. Manual de PHP: json_encode
6. Manual de PHP: header
7. Manual de PHP: subida de ficheros con el método POST